

Demystifying FedRAMP Vulnerability Prioritization with Math

Tony Steiner

Director of Compliance, stackArmor

FedRAMP recently released their 2026 Consolidated Rules introducing a series of new requirements and suggestions to modernize the FedRAMP Rev5 and 20X Certification paths. Among those updates is one significant shift concerning tracking vulnerabilities, specifically the Vulnerability Disclosure Report (VDR) and Vulnerability Evaluation Requirements (VER). Providers must assign a Potential Agency Impact N-rating (PAIN) level ranging from N1 to N5 and adhere to strict remediation timeframes based on **likely exploitability** (Likely Exploitable Vulnerability [LEV] vs. Not Likely Exploitable Vulnerability [NLEV]) and **internet reachability** (Internet-Reachable Vulnerability [IRV] vs. Not Internet-Reachable Vulnerability [NIRV]).

	Class A/B			Class C			Class D		
PAIN	L+I	L+N	NLEV	L+I	L+N	NLEV	L+I	L+N	NLEV
N5 (Debilitating)	4	8	32	2	4	16	0.5	1	8
N4 (Disruptive)	8	32	64	4	8	64	2	8	32
N3 (Disruptive)	32	64	192	16	32	128	8	16	64
N2 (Narrow)	96	160	192	48	128	192	24	96	192

Note: Values represent days to remediate, mitigate, or attest after detection

Underneath the compliance jargon, this represents a massive shift to the way continuous monitoring is handled. FedRAMP is moving away from fixing vulnerabilities based on abstract scanner scores and static remediation periods of 30(H)/90(M)/180(L) days and, moving instead toward a true, risk-based model. In the past, a risk-based deviation used to mean a formal request and an Authorizing Official's sign-off. Now, that judgment sits with the Cloud Service Provider (CSP), but it cannot be an ad hoc decision independently determined by each analyst.

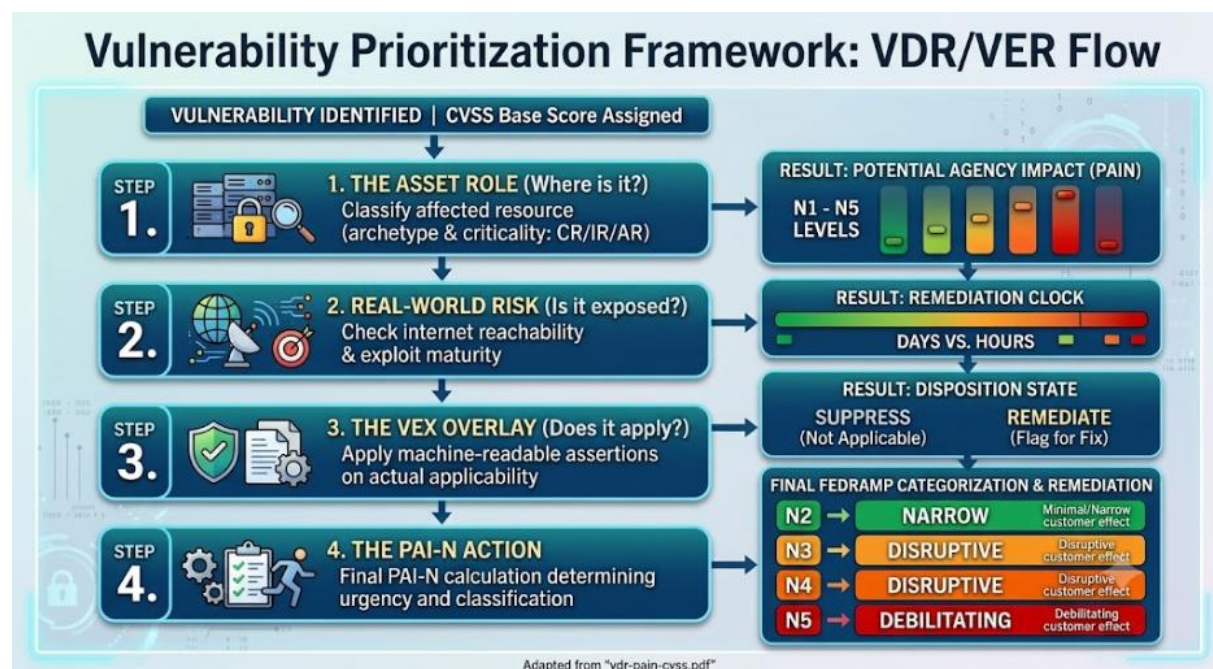
If every cybersecurity analyst in your company tries to guess these impact levels by hand, three things happen:

1. **It's too slow:** Manual triage cannot keep up with thousands of scanner hits.
2. **It's inconsistent:** Two analysts will look at the same flaw and give you different answers.
3. **It's indefensible:** When an auditor asks *why* you gave a vulnerability an N2 instead of an N5, you won't have a reliable paper trail.

This is where a recent memo by Matthew Venne, CTO of stackArmor, argues that a reproducible, deterministic solution already exists in the standard Common Vulnerability Scoring System (CVSS) Environmental metrics. Companies just need to determine how to calculate it.

If you are unfamiliar with CVSS score, this is a rating system currently used by cybersecurity analysts to determine the severity of a vulnerability (10.0 being critically dangerous and 1.0 being mostly harmless) asking only that analyst assign a remediation timeline to that finding directly in proportion to the severity rating. FedRAMP VDR/VER, is now asking, the CSP to answer a different question: *what is the potential impact on the agency and can the scanner finding actually be exploited in this running environment?* Matt states, “The two are not the same. A “Low”-rated CVE on a crown-jewel datastore can carry more agency impact than a “High”-rated CVE on a throwaway sandbox.”

With that understanding in mind, here is a breakdown of how this mathematical model translates scanner outputs into defensible, FedRAMP-compliant compliance metrics.



How the Model Works

- **CVSS Score:** Ingest and account for the severity of the original vulnerability score
- **Asset Archetypes:** Instead of manually scoring every individual server, the method suggests grouping assets into archetypes. For example, a database might be tagged as "data-sensitive," while an ingress controller is tagged as "public-edge". Each

archetype comes with pre-assigned CR/IR/AR criticality requirements, making the scoring systematic, repeatable, and auditable.

- **Threat Intelligence Integration:** The method pulls two crucial facts from CISA Vulnrichment:
 - Exploitation State: Is this actively being exploited by threat actors?
 - Technical Impact: How bad would this attack be to the system?

If exploitation is "active," the remediation clock tightens regardless of its base probability. If the technical impact grants "total" control, the PAIN level can escalate.

- **Scope and Blast Radius:** The formula should account for whether an asset serves a single agency or multiple agencies. A shared component holding data for multiple tenants will receive a higher PAIN level than a single-agency system.
- **Remediation Deadlines:** The final deadline to fix a vulnerability is selected from a timeframe matrix. This matrix uses the provider's Certification Class (A-D), the calculated PAIN level, and an exploitability column derived from internet reachability and exploit likelihood.

The Role of Disposition and Vulnerability Exploitability eXchange (VEX)

Scoring determines how bad a finding is and how fast it must be fixed, but a scanner's hit is not always a confirmed problem in a real-world environment.

Once a vulnerability is scored, the model relies on Vulnerability Exploitability eXchange (VEX) to record the post-detection disposition. This step determines if the specific deployment is truly affected, or if the finding can be suppressed (e.g., the vulnerable code is unreachable) or accepted with a mitigation plan. This ensures that any downgrade in apparent risk is recorded in a machine-readable, auditable, and reversible format.

Why This Matters

The bottom line to the introduction of a mathematical solution appears to be a must in order to adhere to the new FedRAMP VDR/VER mandates. FedRAMP did not provide a solution and stackArmor has worked to provide a potential solution. To learn more about the specifics of this mathematical solution please read: <https://stackarmor.github.io/rfc-fedramp-vdr/>. By adopting a closed-form mathematical approach rooted in CVSS Environmental metrics CSPs can remove the guesswork from their compliance pipelines ensuring that every vulnerability receives a consistent, justifiable PAIN rating and remediation deadline.